

AI Interview Platform Remediation Report

Scope: P0-P3 assessment; P0-P2 remediation
Date: 2026-08-19
Source of truth: FEATURES.md and repository source

Note: The referenced brief-fullstack.pdf was not present in the workspace, so its exact visual template could not be reproduced. This report uses a release-assessment structure and is also exported as remediation-report.pdf.

Executive Summary

The assessor and candidate main flows were reviewed from authentication through assessment setup, invitation, live interview, portfolio generation, fit/gap analysis, and export. P0-P2 findings were fixed. P3 findings are documented only, as requested.

Severity	Found	Fixed	Remaining
--- ---:	---:	---:	---:
P0	2	2	0
P1	2	2	0
P2	2	2	0
P3	5	0	5

P0 Findings and Fixes

P0-01 Cross-tenant portfolio access

Risk: Direct portfolio and portfolio-skill endpoints loaded records by global IDs. Because those tables have no tenant_id, an authenticated assessor could access another tenant's portfolio, fit/gap report, export, or override by guessing IDs.

Fix: Direct portfolio and portfolio-skill queries now join through sessions and require sessions.tenant_id to match the resolved tenant. Vacancy lookups remain tenant scoped, and PDF export now rejects an explicitly requested vacancy that is not visible to the current tenant.

Changed: api/app/controllers/api/v1/portfolios_controller.rb,
api/app/controllers/api/v1/portfolio_skills_controller.rb

P0-02 WebSocket role bypass

Risk: Audio and coverage WebSocket JWT paths validated signature and tenant ownership but did not enforce assessor/admin roles. Any valid role in the tenant could use assessor WebSocket access.

Fix: Both WebSocket JWT paths now require a role in AuthorizeApiRequest::ASSESSOR_ROLES. Candidate audio access remains invite-token based.

Changed: api/app/channels/audio_websocket_middleware.rb,
api/app/channels/coverage_websocket_middleware.rb

P1 Findings and Fixes

P1-01 Taxonomy identity discarded

Impact: Selecting a taxonomy skill intentionally set skill_id to undefined. Fit/gap matching then depended on labels, making renamed or similarly named skills unreliable.

Fix: The picker now persists the taxonomy skill_id; shared TypeScript types now match the API's string identifier.

Changed: web/src/components/assessment/SkillPicker.tsx, web/src/types/index.ts

P1-02 Unknown routes render a blank application

Impact: Invalid or stale links had no matching route and produced an empty screen, interrupting navigation and recovery.

Fix: Added a wildcard not-found screen with a clear return path to assessments.

Changed: web/src/App.tsx

P2 Findings and Fixes

P2-01 Health checks reported false readiness

Impact: Both health endpoints always returned ok, even when PostgreSQL or Redis was unavailable. Kubernetes could route traffic to an unusable API.

Fix: /health and /api/v1/health now check PostgreSQL and Redis, return individual check states, and use HTTP 503 with degraded status on failure.

Changed: api/app/controllers/health_controller.rb,
api/app/controllers/api/v1/health_controller.rb, api/config/routes.rb

P2-02 Export accepted inaccessible vacancy IDs silently

Impact: A requested vacancy outside the tenant resolved to no vacancy and silently generated a portfolio-only PDF, masking authorization/input errors.

Fix: PDF export now returns 404 Vacancy not found when a supplied vacancy cannot be resolved in the current tenant.

Changed: api/app/controllers/api/v1/portfolios_controller.rb

P3 Findings (Not Fixed)

1. Candidate invite tokens have no expiry, rotation, or revocation lifecycle.
2. Assessment and vacancy list pages do not expose API pagination controls.
3. Assessment language cannot be changed from the edit screen.
4. Browser compatibility detection does not enforce a supported-browser policy.
5. Audio output preflight checks API availability but does not confirm that the candidate heard sound.

Main Flow Verification

Flow	Verification	Result

Web application compile and bundle	npm run build	Pass
Assessor REST tenant boundaries	Static trace through tenant-scoped models and direct-ID joins	Pass
Candidate invitation and interview access	Static trace of invite-token candidate endpoints and audio WebSocket ID match	Pass
Assessor live monitor access	Static trace of JWT signature, tenant, role, and session checks	Pass
Portfolio, override, fit/gap, export	Static trace of session tenant joins and vacancy scopes	Pass
API route integrity	Static route/controller resolution review	Pass
Patch whitespace validity	git diff --check	Pass
Rails boot and automated specs	Ruby/Bundler unavailable on host; repository has no specs	Not run

Release Assessment

All identified P0-P2 findings in this assessment are remediated. The frontend production build succeeds. Backend runtime confidence is limited by the absence of Ruby, PostgreSQL, and Redis in the execution environment and by the repository's lack of automated tests. Before production release, run Rails boot, request tests, and an end-to-end interview against configured PostgreSQL, Redis, Sidekiq, and Gemini services.